

Ciberlab - Sistema de Gestión OT

Documento Confidencial

INFORME DE AUDITORIA DE SEGURIDAD TI - CONFIDENCIAL

Planta de Gas Cuadrante 2 | Departamento de Sistemas | Agosto 2026

=====

AUDITOR: Ing. R. Contreras (Administrador de Sistemas TI)
FECHA: 15/08/2026
ESTADO: PENDIENTE DE MITIGACION

RESUMEN EJECUTIVO

Se realizó una revision de la configuracion de seguridad del sistema web de gestion de planta (Ciberlab OT Dashboard). Se detectaron hallazgos que requieren accion inmediata antes del evento de evaluacion programado.

HALLAZGOS CRITICOS

[CRITICO - CVE-INTERNO-2026-001]

La clave secreta de autenticacion del backend (JWT_SECRET_KEY) se encuentra definida en texto plano directamente dentro del modulo de configuracion de tokens: app/auth_config.py

Extracto del archivo comprometido (app/auth_config.py):
 JWT_SECRET_KEY = '...' <- linea 7

Se separaron las credenciales de base de datos para protegerlas, pero la clave de firma JWT aun reside en texto plano en este archivo. Se recomienda migrarla a variables de entorno (.env) o Vault antes del evento para evitar forjado de credenciales de Administrador.

[ALTO - CVE-INTERNO-2026-002]

El endpoint de descarga de reportes (/api/gas/reports/download) no valida que la ruta del archivo solicitado se mantenga dentro del directorio de reportes autorizado. Esto podria permitir a un usuario autenticado leer archivos arbitrarios del sistema de ficheros del servidor mediante secuencias de path traversal (ej: ../).

Recomendacion: Implementar validacion con os.path.abspath() y verificar que la ruta resultante comienza por el directorio base de reportes.

ESTADO DE MITIGACION

CVE-INTERNO-2026-001: [PENDIENTE] Responsable: Ing. Contreras

Ciberlab - Sistema de Gestión OT

Documento Confidencial

CVE-INTERNO-2026-002: [PENDIENTE] Responsable: Ing. Contreras

NOTA: Ambas vulnerabilidades deben corregirse ANTES del evento.

Si no se corrigen, un usuario autenticado con conocimientos técnicos podría escalar privilegios a nivel de Administrador del sistema (role = user a role = admin).

FIN DEL INFORME
=====